

E-Commerce API — Role-Based Endpoints

NestJS + MongoDB · Single-vendor (admin-owned) · Roles: Guest, Customer, Admin

Role legend:	Guest — no auth required	Customer — requires valid JWT, role=customer	Admin — requires valid JWT, role=admin
---------------------	--------------------------	--	--

1. Auth

Method	Endpoint	Role	Description
POST	/api/auth/register	Guest	Register a new account (default role: customer)
POST	/api/auth/login	Guest	Log in, receive access/refresh tokens
POST	/api/auth/refresh-token	Customer	Exchange refresh token for new access token
POST	/api/auth/logout	Customer	Invalidate current session/refresh token
POST	/api/auth/forgot-password	Guest	Request a password reset email
POST	/api/auth/reset-password	Guest	Reset password using reset token
POST	/api/auth/verify-email	Customer	Verify email using emailed verification token

2. User

Method	Endpoint	Role	Description
GET	/api/users/me	Customer	Get own profile
PATCH	/api/users/me	Customer	Update own profile (name, etc.)
PATCH	/api/users/me/password	Customer	Change own password (bumps credentialChangedAt)
DELETE	/api/users/me	Customer	Soft-delete own account (sets deletedAt)
GET	/api/users/me/addresses	Customer	List own addresses
POST	/api/users/me/addresses	Customer	Add a new address
PATCH	/api/users/me/addresses/:id	Customer	Update an address
DELETE	/api/users/me/addresses/:id	Customer	Delete an address
GET	/api/users/me/payment-methods	Customer	List own saved payment methods
POST	/api/users/me/payment-methods	Customer	Add a payment method (tokenized only)
PATCH	/api/users/me/payment-methods/:id/default	Customer	Set a payment method as default
DELETE	/api/users/me/payment-methods/:id	Customer	Remove a payment method
GET	/api/admin/users	Admin	List/search/filter all users

Method	Endpoint	Role	Description
GET	/api/admin/users/:id	Admin	Get any user's full profile
PATCH	/api/admin/users/:id/ban	Admin	Ban a user (sets status + banReason)
PATCH	/api/admin/users/:id/unban	Admin	Restore a banned user to active
DELETE	/api/admin/users/:id	Admin	Soft-delete a user account
PATCH	/api/admin/users/:id/restore	Admin	Restore a soft-deleted account (sets recoveredAt)

3. Category

Method	Endpoint	Role	Description
GET	/api/categories	Guest	List all categories
GET	/api/categories/:slug	Guest	Get a single category by slug
POST	/api/admin/categories	Admin	Create a new category
PATCH	/api/admin/categories/:id	Admin	Update a category
DELETE	/api/admin/categories/:id	Admin	Delete a category

4. Brand

Method	Endpoint	Role	Description
GET	/api/brands	Guest	List all brands
GET	/api/brands/:slug	Guest	Get a single brand by slug
GET	/api/categories/:id/brands	Guest	List brands belonging to a category
POST	/api/admin/brands	Admin	Create a new brand (linked to a category)
PATCH	/api/admin/brands/:id	Admin	Update a brand
DELETE	/api/admin/brands/:id	Admin	Delete a brand

5. Product

Method	Endpoint	Role	Description
GET	/api/products	Guest	List/search/filter products (by category, brand, price)
GET	/api/products/:slug	Guest	Get product detail by slug
POST	/api/admin/products	Admin	Create a new product
PATCH	/api/admin/products/:id	Admin	Update a product

Method	Endpoint	Role	Description
PATCH	/api/admin/products/:id/stock	Admin	Adjust stock quantity
DELETE	/api/admin/products/:id	Admin	Delete a product

6. Cart

Method	Endpoint	Role	Description
GET	/api/cart	Customer	Get own cart
POST	/api/cart/items	Customer	Add a product to cart
PATCH	/api/cart/items/:productId	Customer	Update quantity of a cart item
DELETE	/api/cart/items/:productId	Customer	Remove an item from cart
DELETE	/api/cart	Customer	Clear the entire cart

7. Wishlist

Method	Endpoint	Role	Description
GET	/api/wishlist	Customer	Get own wishlist
POST	/api/wishlist/items	Customer	Add a product to wishlist
DELETE	/api/wishlist/items/:productId	Customer	Remove a product from wishlist

8. Order

Method	Endpoint	Role	Description
POST	/api/orders	Customer	Create order from cart (checkout)
GET	/api/orders	Customer	List own orders
GET	/api/orders/:id	Customer	Get own order detail
PATCH	/api/orders/:id/cancel	Customer	Cancel own order (if still pending)
GET	/api/admin/orders	Admin	List/search/filter all orders
GET	/api/admin/orders/:id	Admin	Get any order's detail
PATCH	/api/admin/orders/:id/status	Admin	Update order status (paid/shipped/delivered/cancelled)

9. Coupon

Method	Endpoint	Role	Description
POST	/api/coupons/validate	Customer	Validate a coupon code before checkout
GET	/api/admin/coupons	Admin	List all coupons
POST	/api/admin/coupons	Admin	Create a new coupon
PATCH	/api/admin/coupons/:id	Admin	Update a coupon
DELETE	/api/admin/coupons/:id	Admin	Delete/deactivate a coupon

10. Payment

Method	Endpoint	Role	Description
POST	/api/payments	Customer	Initiate payment for an order
GET	/api/payments/:id	Customer	Get status of own payment
GET	/api/admin/payments	Admin	List all payments
GET	/api/admin/payments/:id	Admin	Get any payment's detail
POST	/api/admin/payments/:id/refund	Admin	Issue a refund for a payment

11. Review

Method	Endpoint	Role	Description
GET	/api/products/:productId/reviews	Guest	List reviews for a product
POST	/api/products/:productId/reviews	Customer	Submit a review (requires purchase via orderId)
PATCH	/api/reviews/:id	Customer	Edit own review
DELETE	/api/reviews/:id	Customer	Delete own review
GET	/api/admin/reviews	Admin	List all reviews (moderation queue)
DELETE	/api/admin/reviews/:id	Admin	Remove any review